Aqsa Khalid
Lecturer
School of Computing

CS3002 Information Security

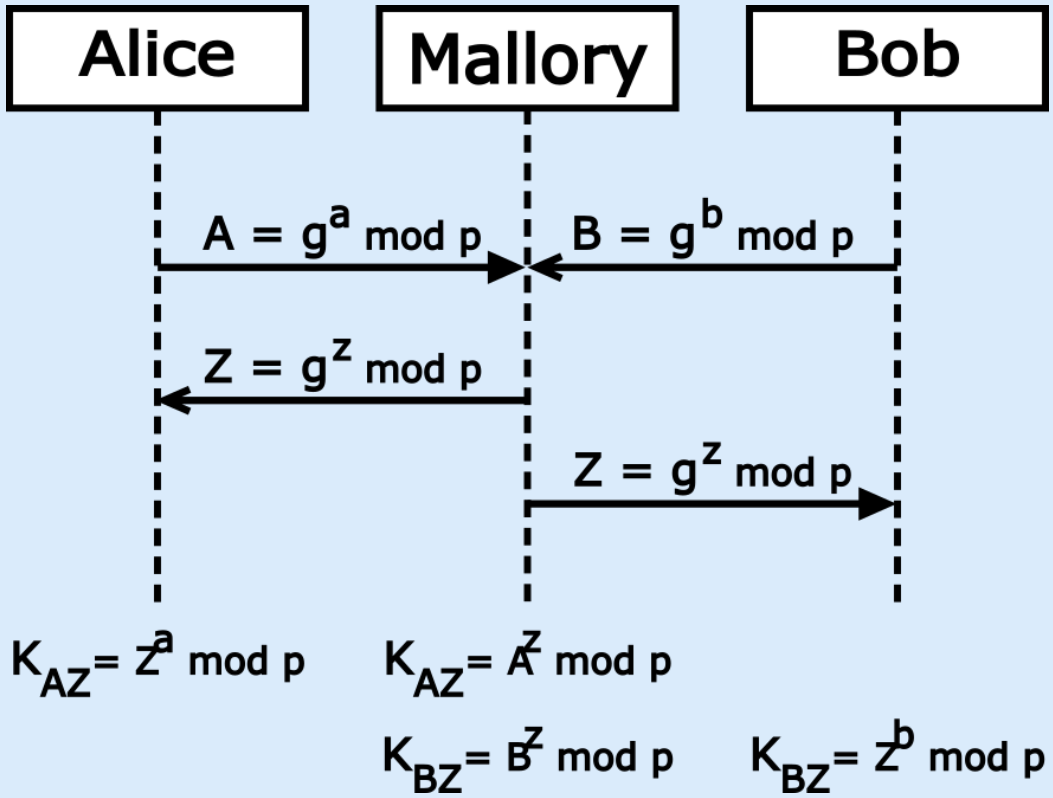


Public Key Infrastructure

MITM against Diffie-Hellman



- Recap: Diffie-Hellman key exchange is vulnerable to main in the middle attack



https://commons.wikimedia.org/wiki/File:Man-in-the-middle_attack_of_Diffie-Hellman_key_agreement.svg

MITM in PKC



- MITM is not unique to Diffie-Hellman key exchange
- All kinds of asymmetric crypto (RSA, digital signatures, digital envelope etc.) is vulnerable to such attacks
- Whenever public keys are exchanged over an insecure channel, we can not blindly trust the ‘authenticity’ of received public key

Public-Key Certificates

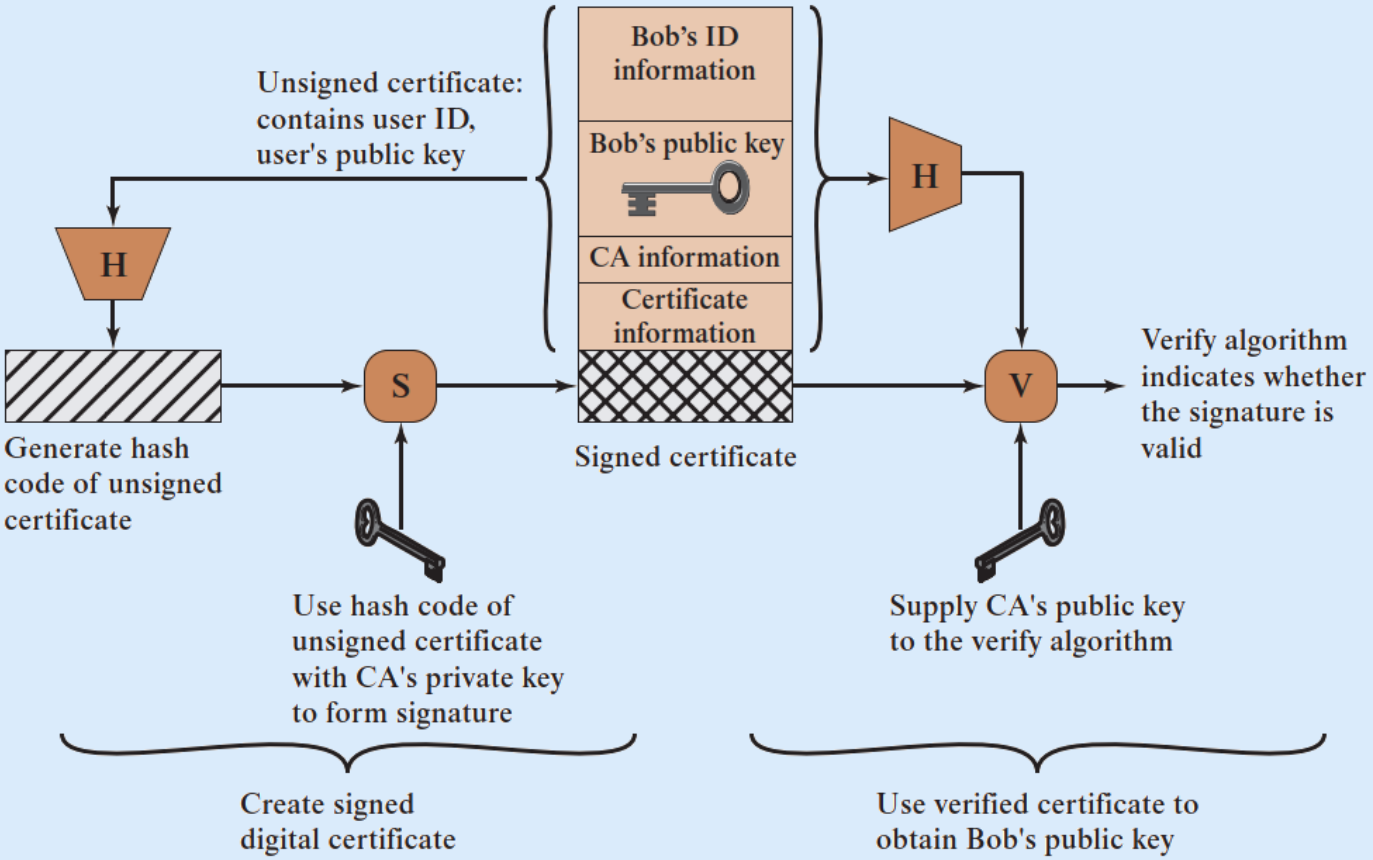


- To prevent MITM against PKC, digital certificates are used
- A certificate associates a public key with an individual/company (i.e. proves key ownership)
- Digital certificate is just a piece of data, containing at least a public key and ID of key owner, whole block signed by a **trusted third party**
- Issued by a Certificate Authority (CA)
- Helps in authentication

Public-Key Certificate



Signing a certificate by CA



Public-Key Certificate



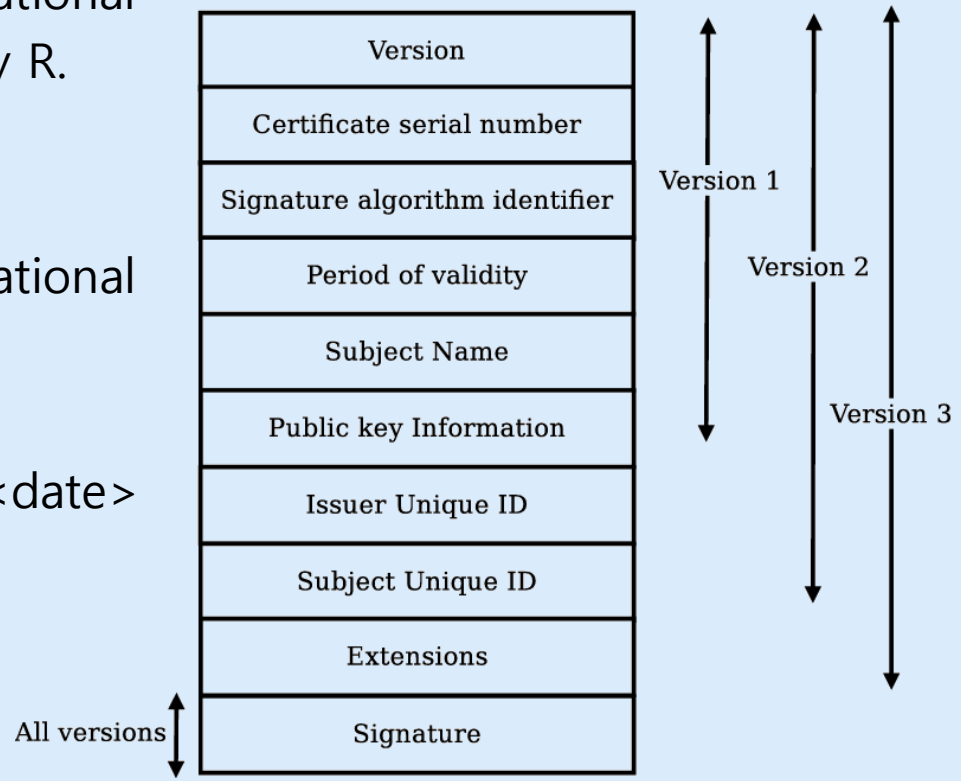
- Certificate contains the following information:
  - who issued it: Comodo, Symantec etc.
  - to whom the certificate is issued (aka the subject)
  - public key of the subject
  - validity period
  - digital signature by CA

- X.509: International Standard for the format of a public-key certificate

X.509 Identity Certificates



- Distinguished Name of subject
  - C=US, O=Lawrence Berkeley National Laboratory, OU=DSD, CN=Mary R. Thompson
- Distinguished Name of issuer
  - C=US, O=Lawrence Berkeley National Laboratory, CN=LBNL-CA
- Validity dates:
  - Not before <date>, Not after <date>
- Subject's public key
- V3 extensions
- CA signatures
- Represented in **ASN.1 notation**
  - which is platform-independent



Public Key Infrastructure (PKI)



- Public Key Infrastructure (**PKI**) refers to the set of hardware, software, and procedures needed to create, store, distribute and revoke digital certificates.

Elements of PKI

- X.509 certificates
- Certificate Authorities (CA)
- Registration Authorities (RA)
- Public/Private key pairs
- Certificate Revocation Lists

Certificate Authority (CA)



- An organization/entity that issues certs
  - Signs and publishes X.509 Identity certificates
  - Revokes certificates when needed, and publishes a Certification Revocation List (CRL)
- Anyone can act as CA and issue certificates, but their certificates will have no value unless the users **trust** them.
- Trusting means the certificate inspector (receiver) already knows about this CA, and has pre-saved the CA's public key in its records.
  - so that they can verify CA's signatures

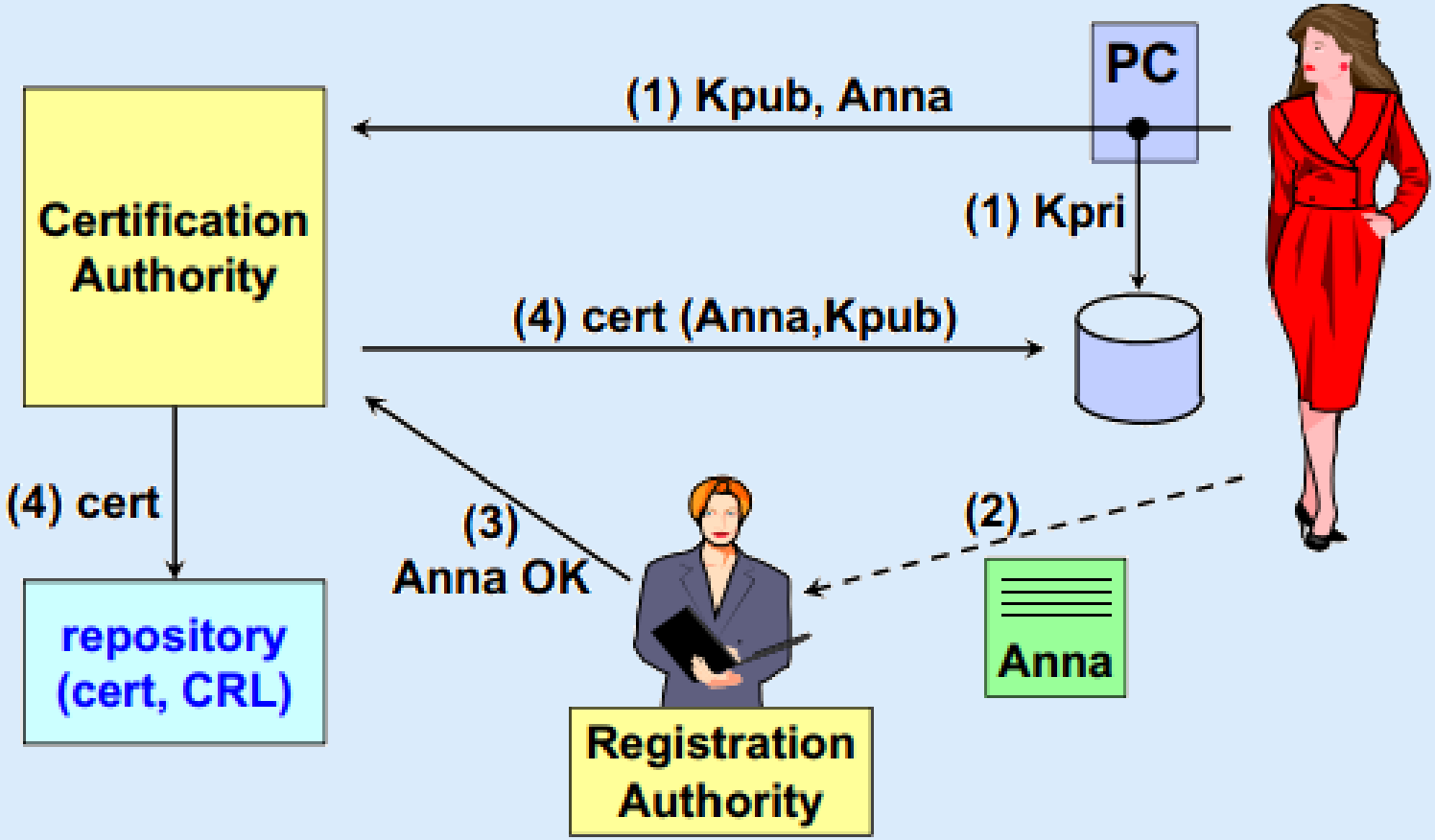
Registration Authority (RA)



- Registration Authority is the logical entity responsible for verifying the identity and eligibility of certificate requester.
- You provide RA with information and fees (if any)
- RA verifies the information, and if valid, forwards it to the CA who will issue the certificate
  - RA does not sign the certificate itself
- Your key pair maybe created by RA or yourself

Certificate Issuance Process





Trusted CAs



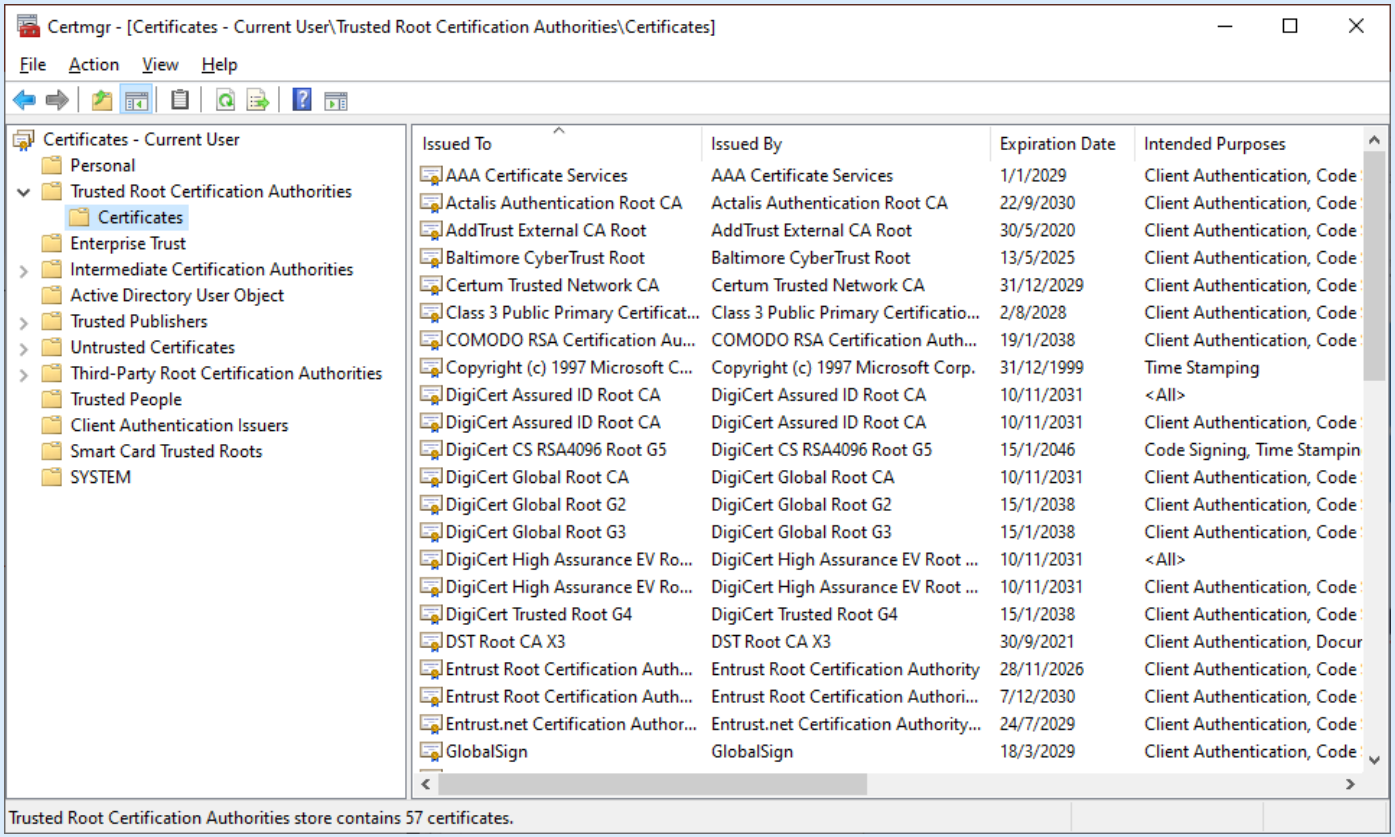
- Operating systems and web browsers come with a pre-installed list of trusted CAs.
- There are several vendors
  - IdenTrust
  - DigiCert
  - Sectigo (Comodo)
  - Lets Encrypt: issues free certificates

- OpenSSL is a free and open source library. It can be used to setup your own CA server.

Trusted CAs – Check your PC



Windows: launch Certmgr.msc

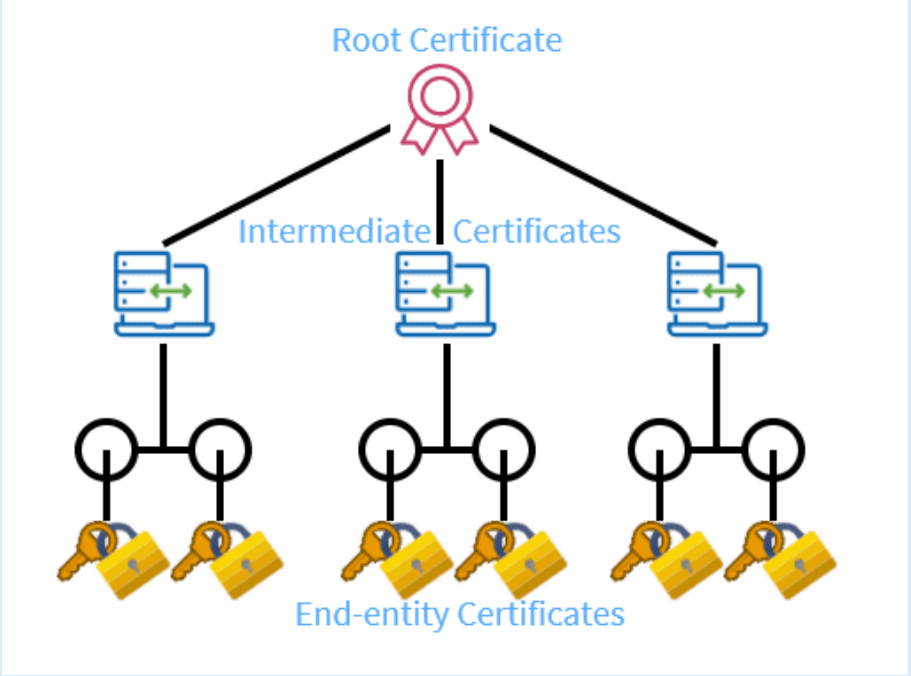


All trusted authorities are present in system's **certificates store**, aka **trust store**.
This is a highly security-critical component of system. What would happen if attackers could manipulate the certificate store?

Chain of Trust

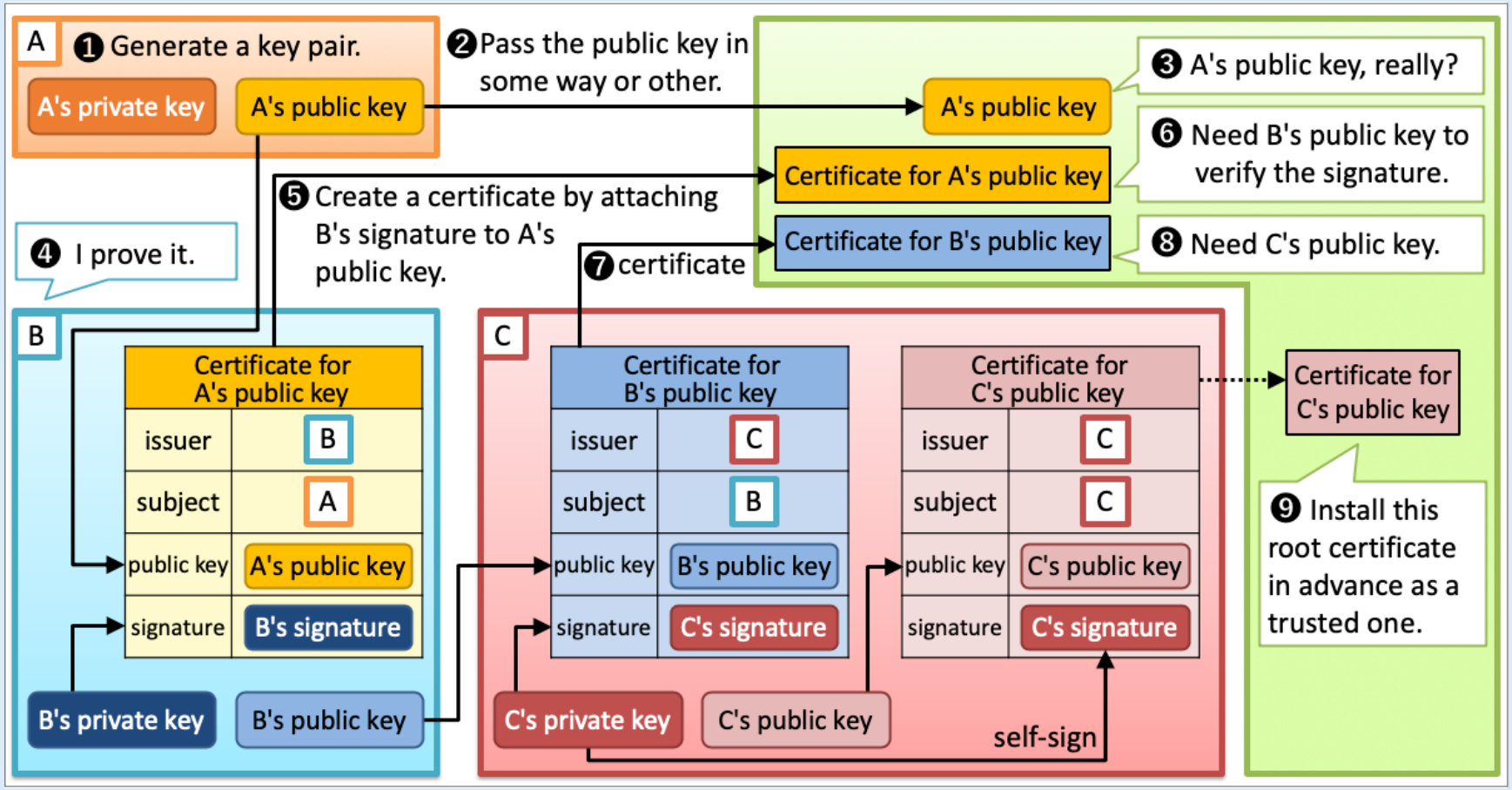


- Instead of getting a certificate directly from a root CA, it is more practical to get one from an intermediate CA which already has a certificate from root CA.
- This hierarchy can go many levels deep



Chain of Trust





https://darutk.medium.com/illustrated-x-509-certificate-84aece2c5c2e

Certificate Revocation

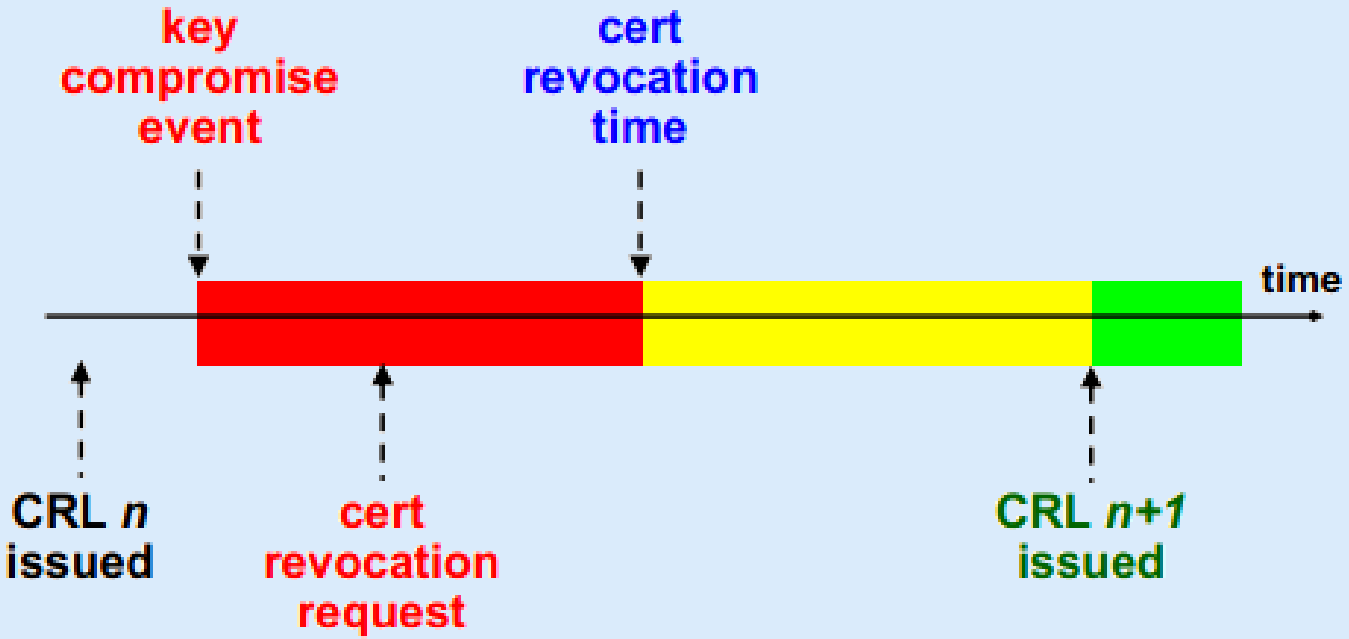


- Certificates may need to be revoked (cancelled), prior to expiration, for several reasons
- Subject may request revocation because
  - Subject's private key was compromised
  - HR reasons, e.g. employee left the company
  - Temporary revocation (on "hold") e.g. resource on leave
  - Subject changed names, physical address, DNS
- CA themselves may decide to revoke because
  - Subject provided false information
  - CA's private key was compromised!

Cert Revocation Lists (CRL)



- CAs maintain lists of revoked certificates. These lists are published by CA frequently.
- A typical timeline of events is as below



CRL Drawbacks



- Certificate revocation lists
  - Large static files
  - Too much work on the client
  - Too much traffic on Internet
- Alternate: Online Certificate Status Protocol
  - CAs maintain an always-online server that responds to revocation status queries (aka OCSP Responder)
  - Provides real-time revocation status of certificates
  - Saves traffic on the internet

OCSP



- Online Certificate Status Protocol (OCSP) is an IETF standard to check online if a certificate is:
  - good/verified
  - revoked
    - revocation time
    - revocation reason
  - unknown
- OCSP servers are operated by, or on behalf of CA.
- response must be signed to ensure that certificate status is authentic
  - which implies that the OCSP responder's certificate must also be checked for validity and revocation!

OCSP Usage



subject server
e.g. youtube.com
(key pair A)

a. request certificate
for public key A

b. issue cert-A

CA server

c. issue
cert-X

1. request
certified
public key

2. here is
cert-A

4. check revocation
of cert-A

OCSP
responder
(key pair X)

end user

5. cert-A revoked
two days ago

must be authentic
response, signed
with private key X

3. ✓ cert-A is not
expired and signed
by a trusted CA

Ahead of time

At communication time

Managing revocations is very challenging



- OCSP was conceived to address challenges in CRL, but it created its own set of problems.
  - OCSP responder may be down, or too slow.
  - Responder could be hacked and go under attacker's control
  - OCSP queries leak users' privacy (browsing history).
- For these reasons, OCSP usage on Internet is shrinking (at least for web browsers).
- Industry is tending towards **short-lived certificates**, that expire within 47 days or earlier.
  - Quicker expiry reduces (though not eliminates) the need for revocation. If a certificate is incorrectly issued, it can only be misused for a smaller duration.

References



- Stallings SPP chap 23
- Digital Certificates Explained - https://youtu.be/5rT6fZUwhG8
- Current state of OCSP and revocation checks - Feisty Duck